QUALITY REPORT

Sample Shop

Generated 1 Nov 2026, 07:31 UTC · Prepared for you@example.com

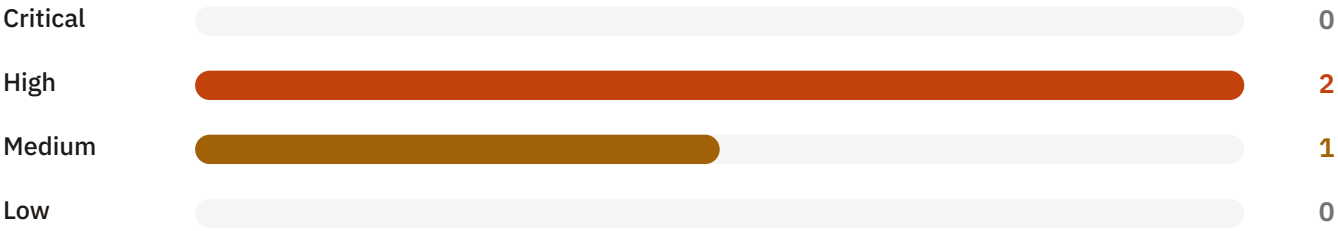
Tiny web shop from examples/sample-shop.

Fix before release

Centinel found 2 serious issues (critical or high risk) that are still open.

Open issues	Serious issues	Code review	Browser test
3	2	Finished	Passed
still to look at	critical or high risk	30 Oct 2026	31 Oct 2026

Open issues by risk level



Critical and high issues should be fixed before you release. Medium and low issues can be planned.

What Centinel checked

Code review	"Pre-release review". Checked 9 files. It is waiting for someone to approve it.	Finished
Browser test	"Sign-in page shows the login form". The website did what the test expected. Recorded 2 steps. Website: http://localhost:4100	Passed
Requirements	1 requirement implemented · 3 partly implemented · 0 missing	

What to do next

1. Fix "Any signed-in user can open another user's order": Look up the order only when order.userId matches the signed-in user, and return "Order not found." otherwise.
2. Fix "Server accepts negative or huge quantities": Validate on the server that every quantity is a whole number from 1 to 10 before calculating the total.
3. Open the latest code review and approve it or request changes.

Top issues explained

The most important open issues, highest risk first.

High risk Code review

Any signed-in user can open another user's order

WHAT IS WRONG

GET /api/orders/:id returns the order without checking that it belongs to the signed-in user, including the shipping address. This breaks REQ-4 (Order privacy).

HOW TO FIX IT

Look up the order only when order.userId matches the signed-in user, and return "Order not found." otherwise.

WHERE

`server.js:76`

High risk Code review

Server accepts negative or huge quantities

WHAT IS WRONG

POST /api/orders trusts the quantity sent by the browser. A request with quantity -3 creates an order with a negative total. REQ-3 says the server must reject anything outside 1-10.

HOW TO FIX IT

Validate on the server that every quantity is a whole number from 1 to 10 before calculating the total.

WHERE

`server.js:65`

Medium risk Code review

Login error reveals which emails have accounts

WHAT IS WRONG

Unknown emails get "No account uses this email." while wrong passwords get a different message, so anyone can check whether an email is registered. REQ-1 requires the same message for both.

HOW TO FIX IT

Return "Email or password is incorrect." for both cases.

WHERE

`server.js:45`

Browser test result

Sign-in page shows the login form

Passed

What it checked	Open the shop and confirm the sign-in form and product list are shown.
Website	http://localhost:4100
Result	The website did what the test expected. Recorded 2 steps.
Summary	The sign-in form and four products were visible.

What the risk levels mean

Critical	Could cause a security breach, data loss or a broken core feature. Fix before release.
High	Likely to break an important feature or expose data. Fix before release.
Medium	Causes problems in some situations. Plan a fix soon.
Low	Minor issue or cleanup. Fix when convenient.

PART 2

Technical details

For developers and auditors: exact IDs, versions and timestamps, the full finding history, evidence and model usage.

About this report

Project	Sample Shop
Project ID	6a1f51f5-96da-43f5-b693-462e57e23cd3
Report ID	f09125e2-68d8-448b-843f-645d51b5be1a
Generated	2026-11-01T07:31:43.006Z
Generated by	you@example.com
Report format version	project-report-v4
Risk policy version	centinel-risk-v1

Risk assessment

Current static risk items	3
Critical / high	0 / 2
Medium / low	1 / 0
Unclassified	0

Dynamic findings are included in the inventory but remain outside this static risk policy.

Current risk items

- high - Any signed-in user can open another user's order (New)
- high - Server accepts negative or huge quantities (New)
- medium - Login error reveals which emails have accounts (New)

Current project findings

1. Any signed-in user can open another user's order

Canonical finding ID	f1
Source module	static
Persisted status	New
Effective disposition	New
Risk level	high
Location	server.js:76
Latest occurrence	Canonical finding
Lineage references	None

2. Server accepts negative or huge quantities

Canonical finding ID	f2
Source module	static
Persisted status	New
Effective disposition	New
Risk level	high

Location	server.js:65
Latest occurrence	Canonical finding
Lineage references	None

3. Login error reveals which emails have accounts

Canonical finding ID	f3
Source module	static
Persisted status	New
Effective disposition	New
Risk level	medium
Location	server.js:45
Latest occurrence	Canonical finding
Lineage references	None

Historical finding occurrences

Saved states in this section are immutable historical occurrences and may repeat one canonical issue. Per-Review findings remain session-scoped.

1. Any signed-in user can open another user's order

Risk	high
Severity / priority	high / high
State	New
Module / category	static / security
Finding ID	f1
Location	server.js:76
Created	2026-10-30T10:00:00.000Z

GET /api/orders/:id returns the order without checking that it belongs to the signed-in user, including the shipping address. This breaks REQ-4 (Order privacy).

Evidence

```
const ok = input === secret;
```

Recommendation: Look up the order only when order.userId matches the signed-in user, and return "Order not found." otherwise.

2. Server accepts negative or huge quantities

Risk	high
Severity / priority	high / high
State	New
Module / category	static / security
Finding ID	f2
Location	server.js:65
Created	2026-10-30T10:00:00.000Z

POST /api/orders trusts the quantity sent by the browser. A request with quantity -3 creates an order with a negative total. REQ-3 says the server must reject anything outside 1-10.

Evidence

```
const ok = input === secret;
```

Recommendation: Validate on the server that every quantity is a whole number from 1 to 10 before calculating the total.

3. Login error reveals which emails have accounts

Risk	medium
Severity / priority	medium / high
State	New
Module / category	static / security
Finding ID	f3
Location	server.js:45
Created	2026-10-30T10:00:00.000Z

Unknown emails get "No account uses this email." while wrong passwords get a different message, so anyone can check whether an email is registered. REQ-1 requires the same message for both.

Evidence

```
const ok = input === secret;
```

Recommendation: Return "Email or password is incorrect." for both cases.

Latest Static Review attempt

Review	Pre-release review
Review ID	r1
Lifecycle state	Need approval
Execution status	Completed
Decision	No decision recorded
Execution time	2026-10-30T10:18:00.000Z (saved completion time)
Created	2026-10-30T10:00:00.000Z
Last activity	2026-10-30T10:20:00.000Z
Decision time	Unavailable

Summary: Reviewed authentication and payment flows.

Reported findings

1. Any signed-in user can open another user's order

Risk	high
Severity / priority	high / high
State	New
Module / category	static / security
Finding ID	f1
Location	server.js:76
Created	2026-10-30T10:00:00.000Z

GET /api/orders/:id returns the order without checking that it belongs to the signed-in user, including the shipping address. This breaks REQ-4 (Order privacy).

Evidence

```
const ok = input === secret;
```

Recommendation: Look up the order only when order.userId matches the signed-in user, and return "Order not found." otherwise.

2. Server accepts negative or huge quantities

Risk	high
Severity / priority	high / high

State	New
Module / category	static / security
Finding ID	f2
Location	server.js:65
Created	2026-10-30T10:00:00.000Z

POST /api/orders trusts the quantity sent by the browser. A request with quantity -3 creates an order with a negative total. REQ-3 says the server must reject anything outside 1-10.

Evidence

```
const ok = input === secret;
```

Recommendation: Validate on the server that every quantity is a whole number from 1 to 10 before calculating the total.

3. Login error reveals which emails have accounts

Risk	medium
Severity / priority	medium / high
State	New
Module / category	static / security
Finding ID	f3
Location	server.js:45
Created	2026-10-30T10:00:00.000Z

Unknown emails get "No account uses this email." while wrong passwords get a different message, so anyone can check whether an email is registered. REQ-1 requires the same message for both.

Evidence

```
const ok = input === secret;
```

Recommendation: Return "Email or password is incorrect." for both cases.

Carryover findings

No carryover findings are persisted for this Review.

Cross-Review classification: available

Source manifest

Status	available
Captured	2026-10-30T10:00:00.000Z
Artifacts reviewed	9

- sample-shop - 9 file(s); hashes: abc123

Traceability

Snapshot status	available
Complete / incomplete / missing	1 / 3 / 0
Attention	3

Review model usage

Calls	208
Input / output tokens	2,630,135 / 11,933
Cache reads / creation	1,428,864 / 0

- codex / gpt-5.6-sol: 208 calls, 2,630,135 input, 11,933 output tokens

Latest existing Dynamic Test

Test	Sign-in page shows the login form
Test ID	d1
Status	Completed
Target	http://localhost:4100
Goal	Open the shop and confirm the sign-in form and product list are shown.
Created / updated	2026-10-31T08:00:00.000Z / 2026-10-31T08:04:00.000Z

Summary: The sign-in form and four products were visible.

Evidence references

No evidence references are recorded.

Action trace

- 1. open - Home page - ok
- 2. check - Sign in text visible - passed

Raw console output and model request/response payloads are not included.

Project sources

Source artifacts recorded	2

- cypress-realworld-app - source_code / github - github:cypress-io/cypress-realworld-app - SHA-256 abc123

Requirements

No structured requirements are recorded.

Coding standards

No coding-standard artifacts are recorded.

Model usage summary

Calls	208
Input / output tokens	2,630,135 / 11,933
Cache reads / creation	1,428,864 / 0

Usage contains provider/model and token counts only. Credentials, prompts, model responses, and hidden reasoning are excluded.